Presentacion de informes y exposiciones de Seguridad en los Sistemas de Información turno noche.

Partiendo de la ISO27002 (norma española que esta en el CVG) realizar presentaciones de gestión de la seguridad de la información de acuerdo a los capítulos de la norma mencionada.

https://frro.cvg.utn.edu.ar/pluginfile.php/284209/mod_resource/content/1/672073777-Norma-ISO-27002-2022-2023-Espanol.pdf

Cada grupo deberá presentar los informes correspondientes y realizar una presentación grupal apoyado por diapositivas.

Además de los capítulos y temas relevantes sobre la normativa mencionada que se utilizará como documentación de base deberán apoyarse en normas y regulaciones relacionadas - ISO27001, apuntes, circulares de organismos regulatorios (BCRA, SSN , etc), información en la web etc.

Los temas están basados en la ISO 27002 mencionada y los grupos se distribuyen según los capítulos y temas.

Cronograma tentativo de presentaciones y exposiciones:

- **6/10 Grupos 1, 2 y 3**
- **13/10 Grupos 3 y 4**
- **20/10 Grupos 5 y 6**
- **27/10 Grupos 7 y 8**
- **3/11 Grupo 9**

En caso de paro, mesas etc el cronograma de exposiciones subsiguientes se desplazarán para las semanas subsiguientes.

Distribucion de grupos según los Capítulos de ISO 27002:

Se indican los temas en general y en el detalle que están mas abajo se enumeran los temas claves a considerar.

1. Controles Organizacionales (Capitulo 5)

Grupos 1 , 2 y 3

A. **Gobernanza, Políticas y Terceros**

Grupo 1 (Ver detalle)

B. **Gestión de Activos, Incidentes y Continuidad**

Grupo 2 (Ver detalle)
Grupo 3 (Ver detalle)

2. Controles sobre las Personas (Capítulo 6)

GRUPO 4

3 – Controles Físicos (Capítulo 7)

Grupos 5 y 6

A. **Perímetros y Áreas Seguras (Grupo 5)**
B. **Seguridad de Equipos e Instalaciones (Grupo 6)**

4. Controles Tecnológicos (Capítulo 8)

Grupos 7, 8 y 9

A. **Defensa Operativa e Infraestructura (Grupo 7)**
B. **Identidades, Criptografía y Ciclo de Vida del Dato (Grupo 8)**
C. **Ingeniería de Software y Seguridad en el Desarrollo (Grupo 9)**

Detalle Ampliado y temas claves mínimos a considerar:

1. Controles Organizacionales (Capitulo 5)

A. Gobernanza, Políticas y Terceros (Grupo 1)

Temas claves:

Políticas de seguridad de la información, Roles y responsabilidades, Segregación de funciones, Contacto con autoridades, Contacto con grupos de interés: Relación con foros de ciberseguridad y especialistas externos s**eguridad en proyectos:** Inclusión de la seguridad de la información desde el diseño de cualquier proyecto. **Identificación de leyes: Cumplimiento de normativas (ejemplo BCRA) , propiedad intelectual y protección de datos (Habeas data, ley de protección de datos personales). Seguridad con proveedores:** Requisitos exigidos a contratistas y socios de negocio.**Servicios en la nube (*Cloud*): Procesos para la adquisición, uso y salida de plataformas en la nube.**

B. Gestión de Activos, Incidentes y Continuidad (Grupo 2 y 3)

Grupo 2

Temas Claves:

- **Inventario de activos:** Registro actualizado de información, software, hardware y servicios **Propiedad de activos:** Asignación de responsables (*owners*) para cada recurso de información. **Uso aceptable:** Reglas

claras sobre qué pueden y no pueden hacer los usuarios con los recursos.**Devolución de activos, Clasificación de la información**

GRUPO 3

Temas Claves:

- **Gestión de incidentes:** Plan integral para reportar y evaluar eventos de seguridad. **Respuesta a incidentes:** Procedimientos para contener, mitigar y aprender de un ataque.**Continuidad del negocio: Planes para que los sistemas de información sigan operando ante catástrofes.**

2. Controles sobre las Personas (Capítulo 6)

GRUPO 4

Temas Claves:

Investigación de antecedentes (*Screening*): Verificación de identidad y referencias antes de contratar. **Términos de empleo:** Contratos que estipulan la responsabilidad legal del empleado en seguridad. **Concientización y capacitación:** Educación continua en ciberseguridad (ej. cómo detectar *phishing*). **Proceso disciplinario:** Sanciones formales si se violan las políticas de seguridad. **Cese de responsabilidades:** Obligaciones de confidencialidad que siguen vigentes tras el despido o renuncia. **Acuerdos de confidencialidad (NDA):** Firmas de compromiso para no revelar datos sensibles a terceros. **Trabajo remoto :** Reglas para proteger la información al trabajar desde el hogar o cafés**. Seguridad de dispositivos móviles:** Políticas de uso para celulares y computadoras portátiles corporativas.

3 - Controles Físicos (Capítulo 7)

Perímetros y Áreas Seguras (Grupo 5)

Temas Claves

Perímetros físicos (Muros, portones, barreras y controles de acceso en la entrada del edificio) **Controles físicos de entrada:** Tarjetas magnéticas,

biometría o personal de seguridad privada **Oficinas y salas seguras:** Restricciones adicionales para departamentos sensibles **Monitoreo físico:** Sistemas de CCTV, alarmas de intrusión y patrullajes **Protección contra amenazas** Sistemas contra incendios, inundaciones y terremotos. **Trabajo en áreas seguras:** Protocolos de conducta dentro de zonas críticas (ejemplo no ingresar con celulares) **Áreas de carga y descarga:** Puntos donde se reciben mercaderías aislados de las oficinas operativas.

Seguridad de Equipos e Instalaciones (Grupo 6)

Temas Claves

Emplazamiento de equipos: Ubicación estratégica de servidores **Seguridad de servicios públicos:** Protección de la energía eléctrica (UPS), aire acondicionado y conectividad **Seguridad del cableado:** Blindaje de cables de red y energía para evitar cortes o intercepciones **Mantenimiento de equipos:** Revisiones periódicas para asegurar el correcto funcionamiento del hardware **Retiro de activos:** Autorizaciones necesarias para sacar un equipo físico de las instalaciones **Seguridad fuera de las instalaciones:** Reglas para proteger equipos cuando se usan en viajes o eventos. **Escritorio y pantalla limpia:** Obligación de bloquear la PC al levantarse y no dejar papeles con contraseñas.

4. Controles Tecnológicos (Capítulo 8)

Grupos 7, 8 y 9

Defensa Operativa e Infraestructura (Grupo 7)

Medidas técnicas orientadas a proteger la red, los servidores, los dispositivos y a mantener la visibilidad de lo que ocurre en el entorno digital de la empresa (Operaciones y Monitoreo).

Temas Claves:

- **Protección contra malware:** Implementación de antivirus, EDR y defensas contra código malicioso.**Seguridad en redes:** Configuración de firewalls, pasarelas de seguridad y defensa perimetral digital. **Segregación de redes:** División de la red en zonas (ej. separar servidores de la red de invitados).**Copias de seguridad (*Backups*):** Respaldos periódicos, almacenamiento seguro y pruebas de restauración. **Registros de eventos (*Logging*):** Activación de bitácoras para auditar acciones de usuarios y sistemas. **Monitoreo de actividades:** Sistemas (como SIEM) para analizar anomalías en tiempo real. **Gestión de vulnerabilidades:** Escaneos técnicos constantes y aplicación de parches de seguridad. **Configuración de sistemas (*Hardening*):** Desactivar funciones o puertos innecesarios en servidores y PC. **Restricción de software:** Bloquear la instalación de programas piratas o no autorizados**. Filtrado web:** Restricción de acceso a sitios de internet peligrosos o no corporativos. **Uso de programas de utilidad:** Controlar herramientas técnicas que puedan evadir las defensas.

Identidades, Criptografía y Ciclo de Vida del Dato (Grupo 8)

Centrarse en **quién puede entrar al sistema** y en **cómo se protegen los datos** cuando se guardan, se transmiten o se descartan (Confidencialidad e Integridad).

Temas Claves:

Control de accesos: Restricción de permisos digitales basada en el rol de cada usuario. **Autenticación segura:** Uso de contraseñas robustas y Doble Factor de Autenticación. **Derechos de acceso privilegiado:** Control y auditoría estricta sobre las cuentas de Administrador. **Gestión de credenciales:** Almacenamiento seguro y ciclo de vida de contraseñas o tokens. **Gestión de criptografía:** Cifrado de datos para que sean ilegibles ante robos. **Gestión de claves:** Protección, rotación y almacenamiento seguro de las llaves criptográficas. **Prevención de fuga de datos:** Reglas técnicas para evitar que datos sensibles salgan de la empresa. **Enmascaramiento de datos:** Ocultar datos reales (como números de tarjetas) en entornos de prueba. **Borrado seguro:** Destrucción digital irreversible de la información que ya no es necesaria. **Acceso al código fuente:** Restricción estricta de quién puede ver o modificar el código base de la empresa. **Información en sistemas públicos:** Protección de datos compartidos en redes o plataformas abiertas.

Ingeniería de Software y Seguridad en el Desarrollo (Grupo 9)

Centrarse en los equipos de sistemas, programadores y DevOps. Asegura que el software que la empresa compra o fabrica se desarrolle de forma segura.

Temas claves:

Desarrollo seguro de software: Reglas y estándares de programación para evitar fallas y hackeos **Ciclo de vida del desarrollo:** Inclusión de pruebas de seguridad en cada fase del software. **Requisitos de seguridad en aplicaciones:** Definir qué medidas de protección debe tener un software antes de comprarlo o crearlo **Arquitectura de sistemas segura:** Diseñar plataformas considerando principios de defensa digital. **Pruebas de aceptación:** Validar formalmente que un sistema es seguro antes de pasar a producción. **Ambientes de desarrollo y pruebas:** Separar por completo los entornos de programación de los datos reales de los clientes. **Gestión de cambios:** Controlar, autorizar y registrar cualquier modificación técnica en los sistemas. **Información de pruebas:** Prohibir el uso de datos reales de clientes para realizar testeos de software. **Outsourcing de desarrollo:** Supervisión y exigencias de seguridad cuando se contrata a empresas externas de software. **Seguridad en la instalación de sistemas:** Procedimientos para desplegar software de manera controlada y segura.